

Defense Portfolios for Synthetic Hospital Ransomware Scenarios: A Partially Calibrated Multi-objective Decision Analysis with Full-Space Confirmation

Ashish Agrawal¹ Mukil Dharanidharan¹ Naman Upadhyay¹

¹Independent Student Researchers, Naperville, Illinois, USA

Abstract Cyber-defense portfolios trade service continuity against implementation cost, operational burden, and residual tail risk, and public evidence identifies almost none of the coefficients a simulation of them requires. We report a synthetic, partially calibrated multi-objective decision analysis that classifies every quantity by what identifies it and reports the unidentified ones as declared assumptions rather than estimates.

This version corrects its own predecessor, whose defects we report rather than supersede: an endpoint defined in prose as requiring four clinical services and computed as requiring one; capacity profiles that portfolios could overwrite at zero cost; a frontier reported over a discovery-selected subset; and a protocol that rewrote its own claim to have been frozen. A seventy-test suite passed throughout, because no test asserted a definition.

The rebuilt study evaluates every resolved candidate — 288, 96, and 16 across three capacity profiles — on fresh paired scenarios under a content-addressed protocol committed before any result existed, for 160,000 executions. Scenario counts were set per profile from a pilot precision analysis rather than declared. Ten unidentified coefficients carry prespecified ranges, drawn per scenario and shared across candidates, so objectives are marginal over declared uncertainty rather than conditional on point estimates. 95 candidates are non-dominated on six separately reported objectives and none minimizes all six. Because the comparison is full-space we also report what a restricted holdout cannot: 38 efficient candidates that a discovery-selected subset would never have shown.

The informative results are negative. In the strongest profile the entire purchasable improvement is 2.0 weighted service-hours, and the parameter explaining most of its variance is the model's own false-positive isolation rate rather than anything about the attack. In the weakest, the declared budget leaves sustained clinical-outage probability at 94.5%. Sampling ten coefficients across wide ranges leaves portfolio orderings largely intact; varying one structural assumption does not. Of 9 frozen external benchmarks only 2 can be scored, 3 fail, and none passes. Every number here is generated from a committed results table by script, and a claim audit fails the build when prose and artifacts disagree. The framework supports auditable trade-off exploration within the synthetic model; it does not estimate hospital risk or control effectiveness.

Keywords healthcare cybersecurity; ransomware; multi-objective optimization; Pareto frontier; common random numbers; Monte Carlo simulation; parameter identification; external validation; computational reproducibility

1 Introduction

Ransomware can interrupt care, displace demand to neighboring hospitals, and extend recovery far beyond the restoration of a server. Among 374 publicly reported attacks on U.S. health care delivery organizations from 2016 through 2021, 44.4% mentioned care disruption and 41.7% mentioned electronic-system downtime [1]. WannaCry was associated with lost appointments and reduced activity at affected National Health Service trusts [2]. A month-long U.S. attack was followed by increased demand, longer waits, and stroke-care delays at neighboring emergency departments [3], and related work reported clinical changes at nearby, unaffected hospitals [4, 5]. A first-party incident review documents an attack in which access preceded detonation by roughly eight weeks while restoration unfolded over months [6].

These studies establish that cyber incidents become operational and regional events. None reveals the counterfactual: what the same incident would have done under a different defense portfolio. That counterfactual is what a hospital needs, and it is not publicly observable.

Simulation can supply one by replaying a single latent

incident under different defenses. Doing so honestly raises the two problems this paper is about.

The first is identification. A model of this kind contains dozens of internal coefficients — per-edge transmission, patch effectiveness, isolation success, restoration throughput — and public evidence identifies almost none of them. Public data constrain incident recovery classes, multi-facility breadth, entry-vector families, facility context, control *adoption*, backup outcomes, and patient-flow effects. They do not constrain a segmentation multiplier or a per-step isolation probability. A model that fills every parameter slot with a citation is not better calibrated than one that does not; it is less honest about the same uncertainty. We therefore classify every quantity by what identifies it, and report the unidentified ones as declared assumptions rather than estimates.

The second is the decision. Segmentation, patching, detection, isolation, identity controls, and backup protection impose different costs and workflow burdens. A portfolio that minimizes average disruption may be unaffordable, behave poorly in the tail, or depend on aggressive isolation that removes healthy systems from service. Multi-objective optimization preserves non-dominated

alternatives instead of hiding preference choices inside one score [7, 8], and cybersecurity investment research has long treated defense selection as a constrained decision problem rather than a one-dimensional ranking [9, 10].

1.1 This paper corrects its own predecessor

An earlier version of this study reported a six-objective frontier with a frozen holdout. An audit found defects severe enough that its results could not be repaired by re-analysis. We report them rather than quietly superseding them.

- The sustained-outage endpoint was defined in prose as requiring at least four clinical services and computed in code as requiring one. It was one of six objectives, so the inversion propagated into the frontier, the stability estimates, the finalist rule, and every reported outage percentage. A 70-test suite[†] passed both before and after the definition was corrected, because no test asserted the manuscript’s definition of anything.
- Per-service outage durations were never written to raw output, so the endpoint could not be recomputed at any other service count from the published data. That is why the present study is a fresh run rather than a re-analysis.
- Capacity profiles were overwritten by portfolios at zero cost. Every candidate declared both a segmentation and a backup architecture, the portfolio value always won, and the weakest rung of each ladder was priced at nothing — so a strong hospital could “buy” flat segmentation and connected backups for zero points. Four of the seven frozen high-capacity finalists[†] were such free downgrades.
- The holdout frontier ranged over 57 discovery-selected finalists[†] rather than the resolved candidate space, and was presented without a candidate-set qualifier.
- The “frozen” holdout protocol was rewritten by its own runner on every invocation and contained no hash, commit, or timestamp. Its claim to have been frozen prospectively cannot be checked from the public record, and we do not repeat it.

Figures marked [†] come from the forensic audit of the superseded version, which is committed alongside this work; they describe an artifact that no longer exists and so cannot be regenerated from current tables.

We state this history because a reader is entitled to know which numbers were withdrawn and why, and because the corrections determined what the present design had to be. The superseded data are retained in the repository, marked as uncitable.

1.2 Contribution

The question is narrow:

Which defense portfolios remain Pareto-efficient across mean disruption, tail disruption, sustained clinical outage, non-recovery, normalized cost, and normalized operational burden, when every resolved candidate is evaluated on a fresh paired scenario bank

under a protocol frozen beforehand?

Four contributions. First, an explicit parameter-identification framework that classifies every reported quantity and refuses to present declared assumptions as evidence. Second, a corrected model in which environmental capacity and purchased controls are genuinely separate. Third, a *full-space* confirmatory frontier, which lets us measure directly how many candidates appear efficient only because the candidate that dominates them was never evaluated. Fourth, a reproducibility apparatus in which every number in this manuscript is generated from a committed table, the confirmatory protocol is content-addressed and cannot be rewritten, and a claim audit fails the build when prose and artifacts disagree.

This is a computational decision analysis. It is not an empirical estimate of any hospital’s attack probability, and it is not evidence that any control achieves any effect in a real hospital.

2 Evidence and parameter identification

Every quantity carries an identification class, declared in a machine-readable registry that the analysis code, the tables, and the claim audit all read. The classes are *evidence-constrained* (matched public evidence on a matching population), *externally validated* (an observable output compared against a frozen benchmark), *declared assumption* (a modeling choice, with no evidence claim), *model-internal* (no real-world referent), and *normalized scenario unit* (explicitly not dollars, staff time, or risk).

2.1 What public evidence can constrain

Incident-level disruption and recovery classes are observable: the 2016–2021 cohort documented care disruption in 166 of 374 attacks, electronic-system downtime in 156, scheduled-care delay or cancellation in 38, and ambulance diversion in 16, with durations binned from under one week to over four weeks and a further 67 events of known disruption but unknown duration [1]. Attacked-hospital activity is observable: volume declines of roughly 17–24% in the first week with recovery over about three weeks [11], alongside changes at nearby unaffected hospitals [3, 5]. Facility context is observable through public cost-report data [12]. Control *adoption* is partially observable through sector survey work [13].

These support scenario construction and external validation targets. None is a control-effectiveness estimate.

2.2 What public evidence cannot identify

No public source provides a representative internal hospital network topology, a per-edge transmission probability, a universal patch effectiveness, a segmentation multiplier, a per-step isolation success probability, an identity-compromise spread multiplier, a traversal probability into isolated backups, a node restoration throughput, clinical service functional thresholds, false-positive isolation incidence, or control-specific capital and workflow costs. These are **non-identifiable** from public data and

are reported as declared assumptions throughout.

Two sources are commonly misread, and we name the misreadings because we were at risk of both. Vendor surveys report entry vectors among self-selected respondents across many countries and organization sizes, with categories that are neither exhaustive nor mutually exclusive and that moved substantially between adjacent years [14–16]. They justify named scenarios, not a prevalence. Observational authentication research estimates a large relative reduction in compromise *at covered authentication events* [17]; it does not license multiplying whole-network ransomware probability by that figure, because it says nothing about unenrolled accounts, service accounts, legacy protocols, token theft, or compromised administrators.

Guidance documents [18–20] justify mechanisms and scenario structure. They are not cited as estimating any coefficient.

2.3 What is repaired, and what remains unidentified

Three parameters were previously used in ways this framework does not sanction. They are now repaired, and we describe both the repair and its limits rather than presenting the model as corrected and moving on.

Patching acts on the pathway where patching acts. Every edge is classified by the mechanism that traverses it: exploitation of a vulnerability on the target, use of valid credentials or tokens, or passage through a third-party gateway. A patch removes susceptibility on the first, does essentially nothing against the second, and acts only partly on the third, because the remote side of a vendor path is not the estate’s to patch. Previously a single scalar reduced compromise probability on every edge, which is on the red-line list and unsupported by any cited source.

Identity effects are confined to eligible pathways. A compromised identity zone accelerates credential-mediated traversal only. Previously it multiplied every edge in the network, so an identity breach sped up exploitation of an unrelated unpatched device. Identity controls now carry an explicit coverage and an effectiveness on the covered fraction; the uncovered remainder is what unenrolled accounts, service accounts, legacy protocols and token theft represent [17].

Isolated backups can fail. The traversal multiplier into an isolated backup zone remains zero, because a correctly isolated backup genuinely has no network path. Falsifiability lives instead in two per-incident mechanisms: an isolation lapse, in which a nominally isolated estate turns out to have a usable path after all, and a residual failure covering causes the network does not model — no clean recovery point, a failed restore, compromise of the backup platform’s own identity. Both are drawn once per incident and shared across candidates in a scenario. Survey evidence reports attempted backup compromise in the large majority of healthcare victims and success in a substantial minority of attempts [15]; a mechanism that cannot fail is not a model of any architecture.

The shape of that last repair is worth a sentence, because

the obvious version is wrong. Encoding rarity as a small per-step traversal does not model a rare event: even a two-percent per-step probability compounds to near-certainty across an 72-hour horizon, which models delay rather than rarity. Isolation either holds for an incident or it does not.

2.4 Uncertainty over what remains unidentified

Repairing a mechanism does not identify its coefficients. No public source gives a per-edge transmission rate, a patch effectiveness, an isolation success probability, or a restoration throughput, and labelling these as declared assumptions while computing results at a single point value tells a reader the number is uncertain and then shows them an answer that pretends otherwise.

Each such coefficient therefore carries a **prespecified range**, and one parameter vector is drawn per scenario and shared by every candidate replaying it — exactly as the topology and the entry point are. Parameter uncertainty becomes another latent dimension of the common-random-numbers design: portfolio comparisons stay matched, and every reported objective is marginal over the declared ranges rather than conditional on a point estimate. The ranges are wide where evidence is absent, and that width is the honest width.

Every draw is recorded in every raw row, which makes a variance-based global sensitivity analysis cost no additional simulation: the confirmatory bank is already a Monte Carlo sample over the ranges.

3 Model specification

The full specification is a versioned document in the repository; the endpoint definitions are a Python module that the analysis code, the tables, and the claim audit all read. What follows is a summary.

3.1 Structure and dynamics

The model contains no malware, exploit code, scanning, or connection to real infrastructure. A generated directed graph represents permitted access paths among workstations, EHR, laboratory, pharmacy, imaging, medical-device, administrative, identity, backup, and internet-facing or vendor functions. Nodes move among healthy, compromised, detected, isolated, restoring, and restored states. A node is functional when it is neither compromised nor isolated; false-positive isolation removes healthy nodes from service for a bounded period, which is a modeled operational cost of aggressive automated response rather than an error.

Seven services depend on core and supporting nodes. A service is available at a step when at least 60% of its supporting nodes are functional. Service availability is **binary at each step**, so the model cannot represent degraded operation, downtime procedures, or manual workarounds. The 60% fraction is a declared assumption with no clinical validation.

Each step is 5 modeled minutes and the horizon is 72 hours. Within a step, spread precedes detection, detection

precedes isolation, false positives are resolved, restoration proceeds, and service availability is scored.

Structural assumption S1. Restoration begins only once the estate is contained — once no compromised node remains un-isolated. Real incident response restores in parallel with containment and prioritises clinical systems. This couples the detection and isolation controls to the recovery endpoint through a modeling choice rather than a mechanism. It was undocumented in the previous version; it is named here and varied in the structural sensitivity analysis.

3.2 Capacity is exogenous; controls are additive

A *capacity profile* is the environment a decision-maker inherits: starting patch coverage, detection delay, isolation success, legacy fraction, baseline segmentation, baseline backup architecture, and a normalized budget. The three profile names are neutral scenario labels, not observed hospital classes.

A *portfolio* is a bundle of purchased upgrades layered on top of a profile: segmentation (flat, basic, least-privilege), patch coverage (zero to three ladder rungs), improved detection, rapid same-step isolation, backup architecture (connected, periodic, isolated), and identity controls. Their Cartesian product gives 288 enumerated portfolios.

Two rules make the separation real, and both were absent before.

Upgrade-only precedence. For every posture ladder, the effective setting is the stronger of the profile baseline and the portfolio target. A portfolio can raise a profile's posture, never lower it.

Increment pricing. A portfolio is priced on the rungs it actually buys relative to its profile's baseline, on both the cost and the burden tables. A downgrade costs zero rather than refunding, and a profile is never charged for a rung it already has.

Together these guarantee that exactly one candidate per profile is free — the profile's own untouched posture — which the test suite asserts. They also reduce the resolved candidate space, because a strong profile has fewer decisions left: 288, 96, and 16 behaviorally distinct candidates in the resource-constrained, intermediate-capacity, and high-capacity profiles respectively. The high-capacity count is small because that profile already owns least-privilege segmentation and isolated backups. That is the honest size of its decision space.

3.3 Endpoints

Table 1 gives the six minimized objectives. All are reported separately; no hidden utility function combines them. Defensive isolation node-hours per node is retained as a diagnostic and is not a seventh dominance dimension.

3.4 The sustained-outage endpoint, and a withdrawn justification

This endpoint caused the previous version's central defect, so we set the decision out in full.

The rule is *k-of-n*: a trial qualifies when at least k of the four clinical services each sustain a continuous outage of more than 2 modeled hours. The comparison is strict, and the runs are *not* required to be concurrent — each service is scored on its own longest outage over the horizon, because per-step service states are not retained for every trial. We use the weaker reading and say so wherever the endpoint appears.

An earlier draft of the rebuilt specification set $k = 2$, arguing that $k = 1$ would saturate and $k = 4$ would be too rare to estimate. **The data do not support that argument and we withdrew it.** Across 12,000 paired discovery trials the number of qualifying clinical services is almost perfectly bimodal: 2,598 trials had none and 9,030 had all four, with only 372 trials (3.1%) anywhere in between. Candidate-level outage probabilities therefore differ by about three percentage points between $k = 1$ and $k = 4$, and the interquartile spread across candidates is identical to three decimal places.

Because the choice of k costs nothing in estimability and buys nothing in discrimination, it is settled on construct grounds alone, and we take the strictest reading: $k = 4$, the definition the previous manuscript stated and the code did not implement. Choosing a looser k would have moved the definition closer to where the defect happened to sit, with no evidence for it. Every results table reports all four values of k , so a reader who prefers a different one reads it off the same table.

The bimodality is itself a model artifact. Binary per-step service availability over a shared network structure produces all-or-nothing clinical outcomes, whereas real incidents show partial, degraded, and staggered service loss. This limits what the endpoint can represent regardless of k , and it is a more serious caveat than the choice of k ever was.

3.5 What the recovery endpoint cannot do

Non-recovery is right-censored technical recovery at 72 hours. The restoration rate implies that a few-hundred-node estate is restored within hours once contained, whereas the public incident record has a substantial weeks-to-months tail. **A 72-hour horizon with this restoration rate cannot express the observed tail at all**, so non-recovery is an artifact of the horizon rather than a recovery estimate, and we report it as one. Separating acute service availability, minimum viable operations, and full organizational recovery into distinct endpoints over 72 hours, 21 days, and 90 days, with a 180-day tail scenario, is the next required piece of work and is not attempted here.

Table 1: Decision objectives with the identification class of each. Only simulated outcomes share units with the model. Cost and burden are normalized scenario points.

Objective	Definition	Identification	Interpretation boundary
Mean disruption	Mean weighted service-hours lost across the seven modeled services, each binary at each step	Model-internal	Expected service unavailability within the synthetic model; not patient harm
Tail disruption	Conditional mean weighted service-hours lost among trials at or above the empirical 90th percentile	Model-internal	Severity of the worst simulated decile under the model's own scenario bank
Sustained clinical outage	Fraction of trials in which at least k of the four clinical services each experienced a continuous unavailability run of more than 2 modeled hours, with $k = 4$ primary and every k reported	Declared assumption	A model indicator of multi-service clinical disruption; not an incident probability and not a clinical threshold
Non-recovery	Fraction of trials in which weighted clinical availability had not returned to full at the final simulated step of the declared horizon	Model-internal	Right-censored technical recovery within the horizon; not organizational recovery
Implementation cost	Sum of declared control cost points for the increment a portfolio adds to its profile's exogenous baseline	Normalized unit	A relative scenario weight; not dollars and not procurement evidence
Operational burden	Sum of declared workflow and implementation burden points for that same increment	Normalized unit	A declared scenario preference; not measured staff time or alert volume

4 Study design

4.1 Stage separation

Development, discovery, confirmation, and external validation are separated, and the separation is enforced by artifacts rather than by discipline. Discovery is exploratory: it debugs the specification, estimates Monte Carlo precision, and generates candidate labels. It is labeled non-confirmatory in every output. The confirmatory stage reuses no discovery scenario, and individual cells are never selectively rerun.

4.2 Precision, not round numbers

The scenario count comes from a pilot precision analysis rather than a declaration. For each profile and objective we estimate the per-scenario standard deviation, take the resolution target to be one tenth of the interquartile range of candidate means — the separation the frontier must actually distinguish — and solve for the required scenario count, using the observed within-scenario correlation to obtain the paired requirement that governs a frontier comparison.

Once parameter uncertainty is inside the objectives, that requirement stops being a single number. Most objectives needed between a few dozen and a few hundred paired scenarios. Two returned counts nobody can buy: resource-constrained sustained outage needed 1,422, and high-capacity mean disruption needed 81,534. More strikingly, 3 of the four high-capacity objectives had an interquartile range of *exactly zero* across all 16 candidates in the pilot.

We initially read that as a property of the profile, and the confirmatory data refuted it. At 400 scenarios all 16

high-capacity candidates separate on mean disruption, taking sixteen distinct values across a range of 13.1 to 15.0 weighted service-hours. The zero interquartile ranges were an artifact of a thirty-scenario pilot: at that resolution the achievable outcomes are coarse enough that most candidates tie exactly, and a correlation-based precision estimator asked to size a difference it cannot yet see returns an unattainable requirement.

The lesson is about the estimator, not the profile, and it generalizes: *a precision analysis run on too small a pilot does not report "this quantity cannot be resolved", it reports "this pilot cannot resolve it", and the two are easy to confuse.* The frozen protocol for this study records the stronger reading, because it was frozen before the confirmatory data existed. We report the correction here rather than editing the protocol, which is the point of freezing one.

We used a uniform 400 scenarios per candidate, giving 160,000 confirmatory executions. That is above the attainable requirements and far below the two unattainable ones, so resource-constrained sustained outage remains under-resolved and is reported as such below.

4.3 Full-space confirmation

The confirmatory frontier ranges over every resolved candidate in each profile.

This is the design change that most distinguishes this study from its predecessor. Evaluating only discovery-selected finalists makes the reported frontier conditional on discovery in a way the reader cannot see: a candidate that was mediocre in discovery and excellent on fresh scenarios is structurally unable to appear, and a small restricted set is close to arithmetically guaranteed to be mostly non-dominated in six dimensions. Measured

throughput made the honest version affordable, so we compute the true frontier rather than rename the restricted one.

The previously frozen finalist rule is retained, but it now labels rather than restricts. Because the finalists are a subset of what we evaluate, the finalist-only frontier is a *view of the same data*, and we report directly how many candidates appear efficient only because the candidate that dominates them was never evaluated. That quantity was unmeasurable before.

4.4 Protocol freezing, and an honest statement about the past

The confirmatory protocol is a content-addressed artifact. Its own SHA-256 is computed over its canonical form and stored inside it; the freezing routine refuses to overwrite an existing protocol; loading recomputes the digest and fails if the file has been edited. The runner will not start without a protocol that verifies, refuses to run if the resolved candidate space has changed since freezing, and stamps the digest into every raw row and into the run manifest. The protocol used here is 9cb7e835446a, frozen 2026-09-04T01:53:46Z and committed before any confirmatory output existed.

We do not claim the previous study's freeze was prospective. It cannot be established from the public record, so that analysis is described as retrospective. Only protocols frozen under the mechanism above support a prospective claim, and only from their freeze timestamp forward.

4.5 Pairing and uncertainty

All candidates within a profile replay one scenario bank: the same topology, entry point, patch draws, and counter-style event-level random fields. Controls may delete or modify paths but cannot receive more favorable latent randomness. This is a common-random-numbers design [21].

We distinguish aleatory event variation, parameter uncertainty, structural uncertainty, evidence uncertainty, and Monte Carlo error. Parameter uncertainty enters through the per-scenario draws described above and is therefore inside every reported objective rather than beside it; Monte Carlo error is reported explicitly. Every stochastic objective carries a standard error, and we report the number of candidate pairs separated by less than one combined standard error on every stochastic objective — pairs the scenario bank cannot reliably order, whatever the dominance test says about their point estimates. Frontier stability uses paired scenario bootstraps that resample whole scenario identifiers, preserving cross-portfolio correlation.

5 Results

5.1 Candidate space

The confirmatory bank evaluated every resolved candidate in each profile — 288, 96, and 16 in the resource-constrained, intermediate-capacity, and high-capacity pro-

files — on 400, 400, and 400 fresh paired scenarios each, for 160,000 executions in total.

The candidate counts fall sharply with profile strength, and that is the first substantive consequence of separating capacity from controls. A high-capacity environment already owns least-privilege segmentation and isolated backups, so those are not decisions it can make. What remains is patching, detection, isolation, and identity controls: 16 distinct configurations rather than the 288 the enumeration nominally contains. Under the previous version's precedence rule the same profile appeared to face far more choices, many of them cheaper than doing nothing, because a candidate could sell back the segmentation and backup architecture the profile already had.

Exactly one candidate per profile costs nothing: the profile's own untouched posture. Its mean weighted service-hours lost are 322.1, 179.3, and 15.0 respectively, and these are the reference points against which every purchase should be read.

5.2 Full-space versus finalist-only frontiers

Over the full space, 95 candidates are non-dominated: 64, 22, and 9 by profile. Restricting attention to the 65 candidates that the frozen discovery rule labels as finalists, and recomputing dominance within that subset alone, gives a frontier of 57.

The two views disagree, and how they disagree has changed since the model was repaired (Figure 1).

No candidate is efficient only in the restricted view. The finalist-only frontier contains 0 candidates that the full space dominates. An earlier version of this study, run before the mechanism repairs and without parameter uncertainty, found three such artifacts; with wider objectives and more scenarios per candidate, that particular distortion disappears. We report the zero rather than the earlier three, and note that a design cannot know in advance which it will get.

38 non-dominated candidates were never labelled as finalists at all. This is where the restricted design actually costs something, and it costs more than before: a study evaluating only the finalist set could not have shown those candidates to a reader under any circumstances, and could not have reported that they existed. Of the 65 labelled finalists, 57 remain non-dominated over the full space and 8 do not.

The asymmetry is the useful part. A restricted comparison rarely promotes a candidate that does not deserve it, because the candidates it evaluates were selected for being good. What it reliably does is hide the ones it never looked at, and no amount of care inside the restricted set can detect that, because the evidence needed is exactly the evidence the design discarded.

5.3 Where the decision is live, and where it is not

The three profiles do not merely differ in degree; they pose different kinds of decision (Figure 2).

High-capacity: very little worth buying. All 16 resolved candidates fall between 13.1 and 15.0 weighted

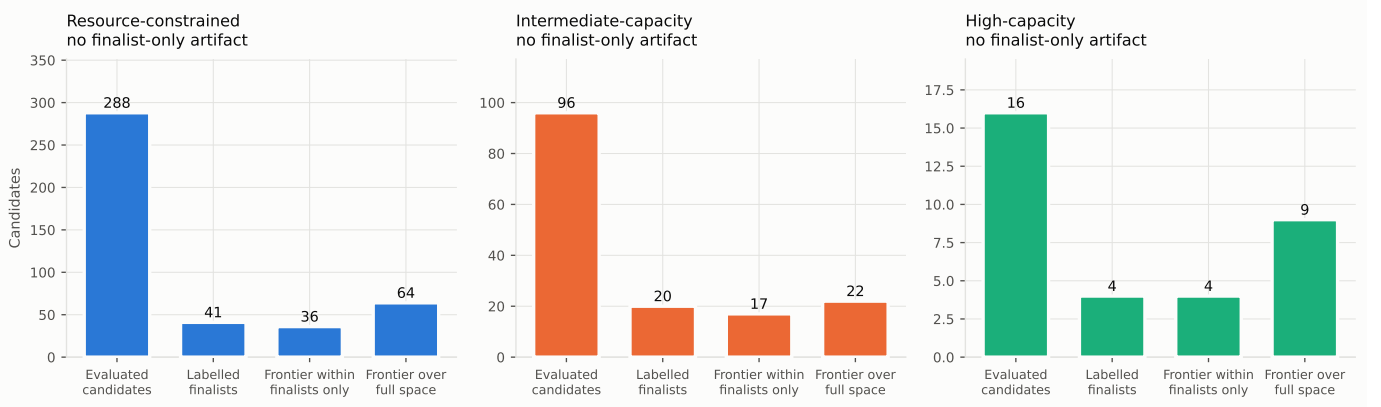


Figure 1: Candidate counts at each stage. The gap between the third and fourth bars is an effect of the candidate set on the reported frontier, not an effect of the data. Panel subtitles give the number of candidates that appear efficient within the finalist subset but are dominated once every resolved candidate is present.

service-hours. The entire purchasable improvement in this profile is 2.0 weighted service-hours, and the best candidate within the 15-point budget spends 14 points to reach 13.1 hours from a free baseline of 15.0. Against a Monte Carlo standard error of 0.7 hours, and with 20 of 120 candidate pairs (16.7%) separated by less than one combined standard error on every stochastic objective, the ordering within this profile is weakly determined and should be read that way.

The sensitivity analysis sharpens this into something more interesting than "the differences are small". In this profile the parameter that explains most of the variance in mean disruption is not the spread rate or patch effectiveness but the *false-positive isolation rate*, at 55.1% of variance. When defenses are strong enough that the attack rarely spreads far, the dominant modeled source of lost service-hours is the defense removing healthy systems from service. That is a conditional model result and not a claim about real hospitals, but it is the kind of trade-off a six-objective frontier exists to surface, and a study reporting only mean disruption would have missed it entirely.

Intermediate-capacity: the decision that matters. The free baseline loses 179.3 hours and the best candidate within the 10-point budget loses 24.3 at a cost of 10 points — a modeled improvement of more than an order of magnitude, with sustained-outage probability at 21.5%. This is the profile in which the six objectives genuinely trade against one another and in which a preference statement changes the answer.

Resource-constrained: the budget does not reach. The free baseline loses 322.1 hours. The best candidate anywhere in the space reaches 77.9, but the best candidate that fits the declared 5-point budget reaches only 157.0, and its sustained-outage probability is 94.5%. Within budget that endpoint is close to immovable: the affordable options change mean disruption substantially while leaving multi-service clinical outage nearly certain. The honest statement is not that some affordable portfolio is adequate. It is that in this modeled environment the declared budget

Table 2: Mean sustained-outage probability across candidates, at every clinical service count k . The primary analysis uses $k = 4$.

Profile	$k = 1$	$k = 2$	$k = 3$	$k = 4$
Resource-constrained	87.3%	84.5%	83.7%	83.4%
Intermediate	57.4%	47.9%	45.8%	44.8%
High-capacity	16.0%	3.6%	2.2%	1.7%

does not buy the outcome the endpoint measures.

5.4 Uncertainty and resolution

Worst-case Monte Carlo standard error on mean disruption is 6.6, 5.4, and 0.7 weighted service-hours in the three profiles.

The share of candidate pairs the scenario bank cannot reliably order is 2.0%, 1.8%, and 16.7%. The high-capacity figure is the one to read carefully: at the thirty-scenario pilot resolution that profile's candidates were indistinguishable to the point of tying exactly, and at 400 scenarios they separate into sixteen distinct values while a sixth of pairs still cannot be ordered. Both facts are about resolution, not about the profile having no decision in it.

Bootstrap Pareto inclusion is at least 0.80 for 44, 21, and 7 candidates respectively.

5.5 The sustained-outage endpoint at every k

Table 2 reports the endpoint at every clinical service count. The values move by roughly three percentage points across the whole range of k , for the reason given in the methods: within this model the clinical estate is close to all-or-nothing (Figure 3). A reader who disagrees with the primary $k = 4$ can substitute any other and reach substantially the same conclusion. That is a statement about the model's behaviour, not a defence of the choice.

5.6 External validation

Of 9 frozen external benchmarks, 2 could be scored numerically. 2 are not addressable because the model has no output of that construct at any parameter setting, and 3 cannot be scored because the model's quantity and the target's quantity are not the same thing. 3 benchmarks

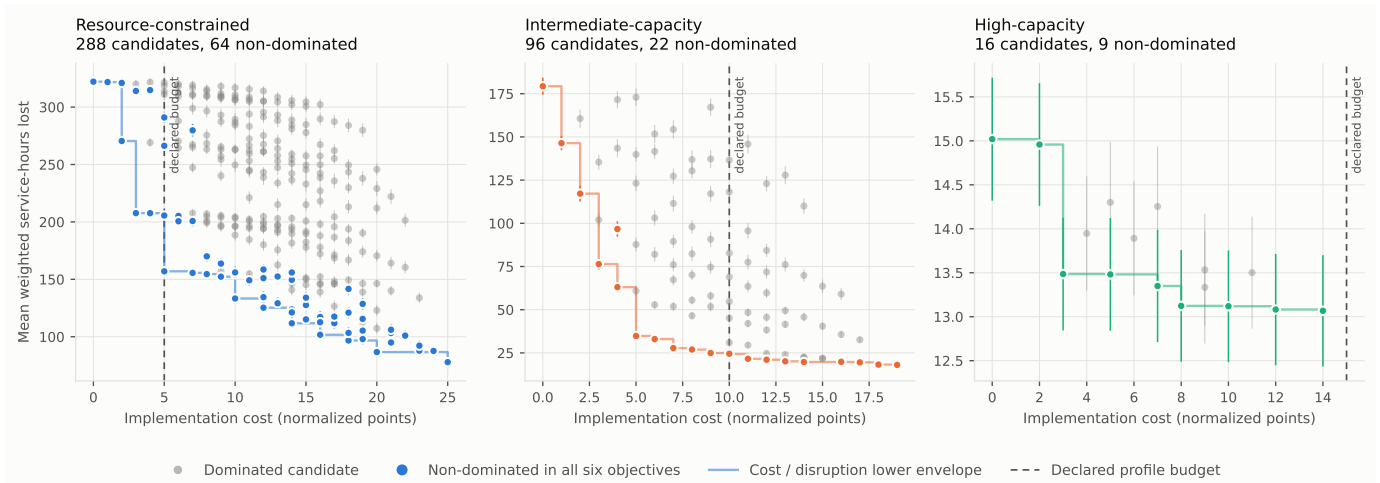


Figure 2: Cost against mean weighted service-hours lost, with Monte Carlo standard errors. Coloured markers are candidates non-dominated across all six objectives; they are deliberately not joined, because a point efficient in six dimensions can sit above another in this two-dimensional projection and connecting them would draw a trade-off curve the data do not contain. The thin step line is the cost/disruption lower envelope: the best mean loss reachable at or below each cost. Note the vertical scales — the high-capacity panel spans under one service-hour.

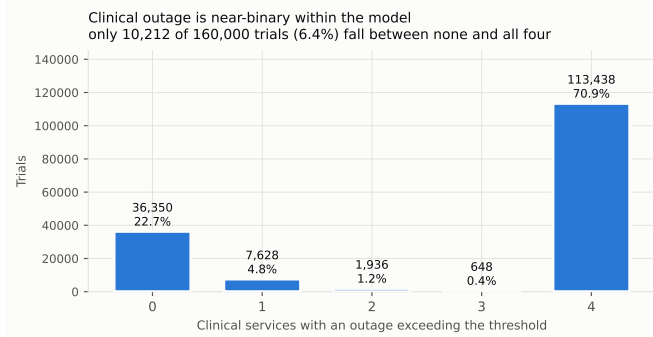


Figure 3: Number of clinical services sustaining a qualifying outage across the discovery bank. The near-binary shape is why the choice of k is not load-bearing — and it is an artifact of binary per-step service availability, not a property of real incidents.

fail. None passes.

That ratio is the headline validation result and it bounds every conclusion above. Three failures are worth stating individually.

The restoration engine is anchored to neither reference. Against the one directly observed large-scale technical hospital outage the model is far too slow: its median clinical outage is 40.9 modeled hours against an observed median of 5.1, and 23.2% of disrupted trials recover within six hours against an observed 58.1% [22]. Against the ransomware incident record the same engine is far too fast, completing inside a 72-hour horizon where the public duration distribution has most of its mass beyond a week [1]. A model simultaneously too slow for a technical outage and too fast for a ransomware incident is anchored to neither, and its non-recovery objective should be read as a within-model ordering device rather than a duration estimate.

Multi-facility breadth fails outright. The simulator runs one facility, so it assigns probability zero to roughly a quarter of publicly reported hospital-linked events —

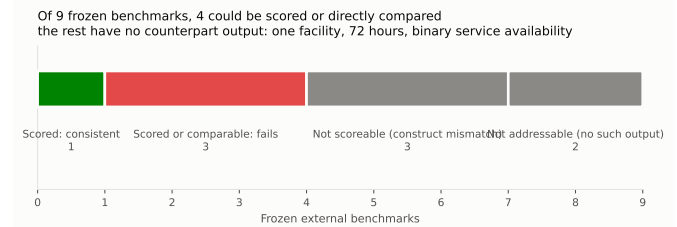


Figure 4: Verdicts against the frozen benchmark registry. Targets and criteria were fixed before any comparison was run, and failures are reported rather than corrected.

those that affected more than one Medicare-certified hospital. This is a total discrepancy on a directly comparable target.

Regional spillover cannot be addressed at all. The model has no representation of a neighboring hospital, patient transfer, or diversion, so the documented burden at adjacent emergency departments [3, 5] has no counterpart output to compare against.

The one benchmark the model is not obviously wrong on is the share of incidents contained before clinical service loss, where the model's spread across profiles brackets the surveyed figure. We report that as consistency rather than a pass: a self-reported vendor survey spanning many countries and organization sizes is not a U.S. hospital denominator, and bracketing a point estimate with a range that wide is weak evidence.

5.7 Sensitivity to the unidentified coefficients

Because every trial records the parameter vector its scenario drew, a variance decomposition costs no additional simulation: the confirmatory bank is already a Monte Carlo sample over the declared ranges. 10 coefficients were sampled.

The results separate two questions that are easy to conflate. In the resource-constrained and intermediate

profiles the dominant parameter for mean disruption is the base spread rate, explaining 6.5% and 17.1% of variance respectively; in the high-capacity profile it is the false-positive isolation rate, at 55.1%.

Those are effects on the *level* of an objective. The effect on the *decision* is much smaller. Ranking candidates within the low and high thirds of each parameter and comparing the two orderings gives Spearman correlations of 0.93, 0.99 and 0.92 for those dominant parameters, with a worst case of 0.61 across all parameters and objectives.

The reading is therefore specific: within the declared ranges, how much disruption a portfolio produces is genuinely uncertain, while which portfolios are preferable is largely stable. That is a weaker and more defensible claim than either "the results are robust" or "the results are uncertain", and it is the claim the analysis supports. It does not extend beyond the ranges, which we chose.

5.8 Structural sensitivity

Assumption S1 — that restoration begins only once the estate is contained — was varied on the 96 candidates carrying the conclusions above. Structural uncertainty behaves quite differently from parameter uncertainty, and the contrast is the point of running both.

Membership. 62 candidates keep their frontier membership under both structures; 21 are non-dominated only under the primary structure and 3 only under the alternative. Per-profile agreement runs from 69.5% to 100.0%.

Magnitude, and its direction. Removing the containment gate makes outcomes markedly *worse*, not better. Intermediate-capacity mean loss across these candidates moves from 46.9 to 107.4 weighted service-hours and non-recovery from 9.2% to 34.3%; the resource-constrained profile moves from 162.6 to 269.8. The high-capacity profile is unaffected, because it contains the estate almost immediately either way.

The direction is initially counterintuitive and the mechanism is worth stating, because it is a genuine property of the model rather than an artifact of the switch. A restored node re-enters the network susceptible. Restoring while the attack is still propagating therefore returns clean assets to an adversary who still has reach, and the incident lengthens. S1 is not a simplifying assumption about scheduling; it encodes the substantive claim that responders do not restore into an uncontained environment, and the model is materially more optimistic because of it.

Set against the previous subsection, the comparison is stark. Sampling ten coefficients across wide declared ranges leaves portfolio orderings largely intact. Changing one structural assumption moves up to 21 candidates off the frontier and nearly doubles modeled disruption in two profiles. Parameter uncertainty is the kind this study can quantify; structural uncertainty is the kind that actually threatens its conclusions, and only one structural assumption of several has been varied.

6 Discussion

6.1 Principal finding

The central result is methodological, and it is not the frontier.

Across 160,000 paired confirmatory executions covering every resolved candidate, 95 portfolios are non-dominated and none minimizes all six objectives. That much replicates what the previous version reported. What is new is that the claim is now checkable in the way the earlier version implied but could not deliver: the comparison ranges over the whole resolved space, so a reader can see what was excluded, which is nothing.

Measuring the difference between the two designs is the substantive contribution. 38 genuinely efficient candidates were never labelled finalists and so could never have been shown, while 0 candidates are efficient only inside the restricted subset. The asymmetry is instructive: a restricted comparison rarely promotes a candidate that does not deserve it, because it evaluates candidates selected for being good. What it reliably does is hide the ones it never looked at, and that error is undetectable from inside the design, because the evidence needed to detect it is exactly the evidence the design discarded. Evaluating the full space costs a few hours of compute and converts an untestable assumption into a reported quantity.

A caution against reading that number as stable: an earlier version of this study, before the mechanism repairs and without parameter uncertainty, found three restricted-view artifacts where this one finds none. The count depends on the model and the scenario budget, so it should be measured per study rather than cited from one.

6.2 What the three profiles actually say

The profiles behave less like a gradient and more like three separate questions, and this became visible only once capacity stopped being purchasable.

In the high-capacity environment there is very little worth buying. The entire purchasable improvement is 2.0 weighted service-hours across a decision space of 16 configurations, and a sixth of candidate pairs cannot be reliably ordered even at 400 paired scenarios. What makes this profile worth reporting is not the small differences but their source: the parameter explaining most of the variance in its mean disruption is the false-positive isolation rate, at 55.1%. Once an estate is strong enough that attacks rarely spread, the dominant modeled cost is the defense removing healthy systems from service. A study reporting a single disruption number would not have seen that, and a study reporting six objectives without a variance decomposition would have seen it only as noise.

The intermediate profile is the only one where the decision is genuinely live. Moving from the profile's own posture to the best affordable portfolio changes modeled mean disruption by more than an order of magnitude, and the declared preference weights select different portfolios. If this framework has a use, it is here: exposing where a preference statement, rather than evidence, is doing the

work.

The resource-constrained profile produces the most uncomfortable and probably the most useful result. Its declared budget buys a large reduction in mean disruption and still leaves sustained clinical-outage probability above ninety percent. Under the modeled assumptions the affordable options do not reach the outcome the endpoint measures. The temptation is to report the best affordable portfolio as the answer; the honest report is that the budget and the endpoint are mismatched, and that a decision-maker in this position is choosing among options that all fail the stated criterion.

6.3 On the endpoint that caused the original defect

The sustained-outage endpoint was inverted in the previous version — prose requiring four clinical services, code requiring one — and correcting it turned out to change very little numerically, because within this model clinical services fail together. That could be read as reassurance. It should not be.

Two things follow instead. First, the near-binary outcome distribution is an artifact of binary per-step service availability over a shared network structure, and real incidents show partial, degraded, and staggered service loss. The endpoint's insensitivity to k is a symptom of a construct limitation, not evidence that the construct is robust. Second, the fact that a wrong definition produced almost-right numbers is precisely why the defect survived: nothing in the outputs looked anomalous. Semantic errors that change results loudly get caught. The ones that matter are quiet, and the only defence against them is asserting the definitions in tests rather than inspecting the numbers.

6.4 Validity, separated

Conflating these is how a computational study acquires more credibility than it has earned, so they are reported separately and the weakest is named as the weakest.

Model validity. The mechanism is an abstract epidemic process on a declared graph. It is defensible as a decision-analysis scaffold and it is not validated against internal hospital telemetry, because no representative public telemetry exists. Three mechanisms that previously acted where they could not act have been repaired, and the coefficients that remain unidentified now carry declared ranges that propagate into every result.

What has not been addressed is structure. Assumption S1 is varied rather than asserted, and the result is a warning about the rest: relaxing that single assumption moves roughly a quarter to a third of frontier membership and nearly doubles modeled disruption in the two weaker profiles. Every other structural choice — the transition ordering within a step, the service dependency graph, the criticality-ordered restoration queue, the absence of an adaptive adversary — is asserted and unvaried, and the one assumption we did test gives no reason to expect the others are gentler.

Data validity. The archived public sources are hash-

verified and every count the registry records re-derives from the file. One source is a normalized export of a browser preview because the original requires sign-in; the recorded hash makes any substitution detectable, and replacing it with the depositor's original is a pre-submission task.

Construct validity. This is the weakest link, and it is weaker than the previous version admitted. Binary per-step service availability cannot represent degraded operation, downtime procedures, or manual workarounds, and that limitation is not merely a caveat — it produces the near-binary clinical outcome distribution reported above, which in turn is why the choice of k makes almost no difference. Weighted service-hours are not patient harm. Normalized cost points are not procurement.

External validity. Topology, transition hazards, service dependencies, control effects, cost, and burden are not jointly observed in any real hospital. Nothing here estimates what a deployed control would do. The frozen benchmark suite is the check on this, and most of it cannot be answered by a model of this shape.

Decision relevance. The outputs support tabletop exploration of where a decision hinges on budget or preference. They do not support procurement, and a portfolio's position on a frontier is not a recommendation.

Computational reproducibility. This is the strongest link, and it is worth being precise about what that buys. Every number above is generated from a committed table by script; every input and output is hashed in a manifest that fails rather than warns; the confirmatory protocol is content-addressed and was committed before any confirmatory output existed; and a claim audit fails the build when prose and artifacts disagree. None of that makes a conclusion true. A perfectly reproducible pipeline reproduces a wrong answer exactly. What it does is make the wrongness locatable.

6.5 Limitations

Reporting bias. Public ransomware incident data record what was publicly reported and linkable. A zero operational flag may mean "not reported" rather than "did not occur", and 67 of 374 events in the incident cohort have known disruption of unknown duration [1] — missingness that is plausibly informative, since longer or more severe incidents may be less likely to have a cleanly reported end date.

Vendor surveys. Entry-vector and backup figures come from self-reported surveys spanning many countries and organization sizes, with non-exclusive categories that moved substantially between adjacent years. They are graded below administrative and peer-reviewed hospital evidence throughout, and they inform scenario names rather than parameter values.

International transferability. The most detailed first-party incident review available is from a non-U.S. health system [6]. It supports mechanism, not magnitude.

Missing denominators. The exploited-vulnerability catalog has no hospital exposure denominator, so its

ransomware-tagged share is not a base rate and is never used as one.

Interval censoring. Recovery evidence arrives in duration bins with a substantial unknown-duration group. Any recovery-class model fitted to it must test the missingness assumption rather than dropping those events.

Absent internal telemetry. There is no representative public measurement of hospital internal network structure. The generated graph is a declared structure, not a measured one, and node counts are not a function of beds.

Elicited thresholds. The service-functional fraction, the outage duration, and the service count are declared choices without clinical validation. Calling any of them a clinical threshold would be false. Unlike the transition coefficients, these are not sampled: a threshold that moves between scenarios would change what the endpoint means rather than how uncertain it is.

Declared ranges are not evidence. Parameter uncertainty makes every objective marginal over ranges we chose. A wide range honestly says "we do not know"; it does not make the resulting interval an empirical one, and a reader should not treat the widened objectives as calibrated because they are now wider.

Cost uncertainty. Normalized points omit procurement, integration, training, maintenance, alert workload, and constraints specific to clinical technology. They are ordinal scenario weights and nothing more.

Adaptive adversaries. The model has none. An attacker who responds to a deployed defense is not represented, so every control effect here is an effect against a static process.

Cross-hospital dependence. The simulator runs one facility. The incident record contains multi-hospital events and documented regional spillover [3, 5]. This is a failure boundary, reported as one rather than absorbed.

Non-causal control effects. No number in this paper is a causal estimate of a control's effect. Every control effect is a conditional model output under declared assumptions.

6.6 What would actually improve this

Not more simulations. The binding constraint is identification, and it is relieved only by data this project does not have: de-identified telemetry from several hospitals, with denominators — asset inventories with patchability and segment membership; vulnerability findings with first-seen, patch-available, and remediated dates; authentication events with coverage, method, and privileged-account class; high-confidence incident timestamps from initial access through recovery milestones; isolation actions with adjudication, release time, and clinical impact; backup architecture with restore-test outcomes and clean-recovery-point availability; and service-level availability with staffing and patient volume. A hierarchical model with hospital-level random effects and explicit measurement error would then be estimable.

Failing that, structured expert elicitation with calibration questions and pooled uncertainty is preferable to point estimates that look empirical. Either way, parameter

mappings should be pre-registered before outcome comparisons are seen, using the same freezing mechanism this study applies to its confirmatory protocol.

Two model changes remain prerequisites rather than refinements, and are named in the specification: layered recovery endpoints over 72 hours, 21 days and 90 days with a 180-day tail, without which the model cannot be compared against the recovery evidence at all; and either multi-facility structure or an explicit narrowing of the paper's scope to a single synthetic facility. Beyond those, the structural sensitivity result argues for varying more than one structural assumption, not merely declaring the rest.

7 Conclusion

We rebuilt a synthetic hospital ransomware decision model after an audit found that its prose and its implementation described different models. The sustained-outage endpoint was defined one way and computed another; capacity profiles were overwritten by portfolios at zero cost; the reported frontier ranged over a discovery-selected subset; and the protocol that claimed to have frozen that subset rewrote itself on every run. A seventy-test suite passed throughout.

The rebuilt study evaluates every resolved candidate on a fresh paired scenario bank under a content-addressed protocol committed before any result existed. 95 portfolios are non-dominated across six separately reported objectives, and none minimizes all of them. Because the comparison is full-space, we can also report what the previous design could not: 0 candidates that look efficient only inside the restricted subset, and 38 efficient candidates it would never have shown.

The findings that matter for a reader are negative ones. In the strongest modeled environment no purchasable control makes a detectable difference to disruption. In the weakest, the declared budget does not reach the outcome the endpoint measures. And of 9 frozen external benchmarks, only 2 can be scored at all — the model has no output matching the rest — while 3 fail and none passes. The restoration engine is simultaneously too slow for the one observed large-scale technical outage and too fast for the ransomware incident record, and the model assigns probability zero to a quarter of observed multi-hospital events.

The defensible contribution is therefore not a defense portfolio and not a frontier. It is a demonstration that the honest versions of three methodological choices — evaluating the full candidate space, freezing a protocol in a way a reader can check, and reporting external validation failures as results — are affordable, and that each converts an assumption a study would otherwise have to make about itself into a quantity it can report. The outputs support research and tabletop exploration *within the synthetic model*. They should not be used as hospital risk estimates, procurement recommendations, or evidence that a deployed control will achieve the reported hours or

probabilities.

Research integrity and declarations

Ethics. The study used synthetic networks, simulated trajectories, public organization-level incident records, a public vulnerability catalog, and published aggregate findings. It involved no participants, patient-level records, private organizational data, malware, or intervention. No external interviews were conducted. Consent, privacy, and institutional requirements must be reviewed before any future human-participant or organizational data collection.

Data and code. Code, configuration, raw simulation outputs, public source snapshots with hashes, processed tables, figures, tests, frozen protocols, and run manifests are at <https://github.com/Dodgeboi/NazeResearchNSRI>. A submitted version should cite a fixed release or archived commit. **No restricted Medicare claims data are included;** the only hospital-linked file is a public replication deposit.

Artificial-intelligence use. Claude, ChatGPT, and Codex were used for coding assistance, debugging, literature-search terms, analysis checks, organization, and editing. An AI system also performed the audit that identified the defects described in the introduction and implemented the corrections, under human direction. AI responses were not treated as evidence. Numerical claims are generated from committed data by script, and literature claims were checked against cited sources. The authors remain responsible for the analysis and the wording. No AI system is an author.

Author contributions. Ashish Agrawal, Mukil Dharanidharan, and Naman Upadhyay developed the project and reviewed the manuscript. Detailed CRediT roles must be agreed before submission.

Funding. The authors report no specific funding for this work.

Conflicts of interest. The authors report no known competing interests. All authors should reconfirm before submission.

References

- [1] Hannah T. Neprash, Claire C. McGlave, David A. Cross, et al. Trends in ransomware attacks on US hospitals, clinics, and other health care delivery organizations, 2016–2021. *JAMA Health Forum*, 3(12):e224873, 2022. doi: 10.1001/jamahealthforum.2022.4873.
- [2] Saira Ghafur, Soren Kristensen, Kate Honeyford, Guy Martin, Ara Darzi, and Paul Aylin. A retrospective impact analysis of the WannaCry cyberattack on the NHS. *npj Digital Medicine*, 2:98, 2019. doi: 10.1038/s41746-019-0161-6.
- [3] Christian Dameff, Jeffrey Tully, Theodore C. Chan, et al. Ransomware attack associated with disruptions at adjacent emergency departments in the US. *JAMA Network Open*, 6(5):e2312270, 2023. doi: 10.1001/jamanetworkopen.2023.12270.
- [4] Thaidan T. Pham, Theoren M. Loo, Atul Malhotra, Christopher A. Longhurst, Diana Hylton, Christian Dameff, Jeffrey Tully, Gabriel Wardi, Rebecca E. Sell, and Alex K. Pearce. Ransomware cyber-attack associated with cardiac arrest incidence and outcomes at untargeted, adjacent hospitals. *Critical Care Explorations*, 6(4):e1079, 2024. doi: 10.1097/CCE.0000000000001079.
- [5] Rahi Abouk and David Powell. Ransomware attacks, emergency department visits and inpatient admissions in targeted and nearby hospitals. *JAMA*, 331(24):2129–2131, 2024. doi: 10.1001/jama.2024.7752.
- [6] Health Service Executive. Conti cyber attack on the hse: Independent post incident review. Technical report, Health Service Executive of Ireland, 2021. URL https://about.hse.ie/api/v2/download-file/file_based_publications/conti_cyber_attack_on_the_hse_full_report.pdf. First-party incident review. Access preceded detonation by roughly eight weeks; restoration unfolded over months.
- [7] Ralph E. Steuer and E.-U. Choo. An interactive weighted Tchebycheff procedure for multiple objective programming. *Mathematical Programming*, 26(3):326–344, 1983. doi: 10.1007/BF02591870.
- [8] Kalyanmoy Deb, Amrit Pratap, Sameer Agarwal, and T. Meyarivan. A fast and elitist multiobjective genetic algorithm: NSGA-II. *IEEE Transactions on Evolutionary Computation*, 6(2):182–197, 2002. doi: 10.1109/4235.996017.
- [9] Lawrence A. Gordon and Martin P. Loeb. The economics of information security investment. *ACM Transactions on Information and System Security*, 5(4):438–457, 2002. doi: 10.1145/581271.581274.
- [10] M. H. R. Khouzani, Zhengliang Liu, and Pasquale Malacaria. Scalable min–max multi-objective cyber-security optimisation over probabilistic attack graphs. *European Journal of Operational Research*, 278(3):894–903, 2019. doi: 10.1016/j.ejor.2019.04.035.
- [11] Hannah T. Neprash, Claire C. McGlave, and Sayeh Nikpay. Hacked to pieces? the effects of ransomware attacks on hospitals and patients. *American Economic Journal: Economic Policy*, 18(1):256–281, 2026. doi: 10.1257/pol.20240594.
- [12] Centers for Medicare & Medicaid Services. Hospital provider cost report data and api, 2023. URL <https://data.cms.gov/provider-compliance/cost-reports/hospital-provider-cost-report/api-docs>. Facility context: beds, FTEs, discharges, revenues, costs, and rural/urban status. Bed counts do not map onto cyber-node counts without a measured correspondence.
- [13] U.S. Department of Health and Human Services. Hospital cyber resiliency initiative: Landscape analysis. Technical report, U.S. Department of Health and Human Services, 2023. URL <https://hhs cyber.hhs.gov/Documents/HICP/HHS-hospital-resiliency-analysis.pdf>. Combines CHIME data from 377 hospitals, a 59-organization Censinet/AHA/KLAS study, threat sources, and 20 hospital interviews. Reports control adoption prevalence, not control effectiveness.
- [14] Sophos. The state of ransomware in healthcare 2025. Technical report, Sophos, 2025. URL <https://assets.sophos.com/X24WTUEQ/at/cq9bfh5g9kpw874qqg5th/sophos-state-of-ransomware-in-healthcare-2025.pdf>. Vendor survey of healthcare ransomware victims across 17 countries and organizations of 100–5,000 employees. Self-reported; not a probability sample of hospitals.
- [15] Sophos. The state of ransomware in healthcare 2024. Technical report, Sophos, 2024. URL <https://www.sophos.com/en-us/blog/the-state-of-ransomware-in-healthcare-2024>. Self-reported vendor survey. Backup-compromise figures are conditional on respondents who reported an attempt.
- [16] Verizon. 2026 data breach investigations report: Healthcare snapshot. Technical report, Verizon, 2026. URL <https://www.verizon.com/business/resources/reports/2026-dbir-healthcare-snapshot.pdf>. Sample is broader than ransomware and broader than hospitals; categories are not a mutually exclusive partition of the model’s entry classes.
- [17] Microsoft Research. How effective is multifactor authentication at deterring cyberattacks?, 2022. URL <https://www.microsoft.com/en-us/research/publication/how-effective-is-multifactor-authentication-at-deterring-cyberattacks/>. Observational study of commercial Azure AD authentication activity. Estimates a relative reduction at covered authentication events only; it does not identify a hospital-wide identity effect.
- [18] Cybersecurity and Infrastructure Security Agency, Federal Bureau of Investigation, National Security Agency, and Multi-State Information Sharing and Analysis Center. Stopransomware guide. Technical report, CISA, 2023. URL <https://www.cisa.gov>.

- [gov/resources-tools/resources/stopransomware-guide](https://www.nist.gov/resources-tools/resources/stopransomware-guide).
- [19] William Fisher, Murugiah Souppaya, William Barker, and Karen Kent. Ransomware risk management: A cybersecurity framework 2.0 community profile. Technical Report NIST IR 8374 Rev. 1, National Institute of Standards and Technology, 2026.
 - [20] U.S. Department of Health and Human Services. Health-care and public health sector cybersecurity performance goals, 2026. URL <https://hhs cyber.hhs.gov/cybersecurity-performance-goals.html>. Accessed July 18, 2026.
 - [21] Vince Buffalo, Carl A. B. Pearson, and Daniel Klein. Realizing common random numbers: Event-keyed hashing for causally valid stochastic models, 2026.
 - [22] Jeffrey Tully, Justin Selzer, Andrew Phillips, and Christian Dameff. Patient care technology disruptions associated with the crowdstrike outage. *JAMA Network Open*, 2025. URL <https://pmc.ncbi.nlm.nih.gov/articles/PMC12276631/>. A non-malicious technical outage. Usable only as a short-duration technical-recovery benchmark, never as a ransomware recovery distribution.